03.10.2024

Romsis Yazılım ve Bilgi Teknolojileri Ltd. Şti.

Kaynak Kodu Analiz Raporu v1.1

Proje Adı:

Ajet Inflight

Analiz Tarihi:

23.08.2024

RSU
Bilişim ve Danışmanlık

GİZLİ

İçindekiler

YÖNETİCİ ÖZETİ 2
Test Kapsamı 5
Uyarı 5
Kaynak Kodu Analizi Metodolojisi 6
Kaynak Kodu Analizi Bulguları 7
1. Kritik Seviye Bulgular 7
2. Yüksek Seviye Bulgular 7
3. Orta Seviye Bulgular 7
4. Düşük Seviye Bulgular 7

GİZLİ

YÖNETİCİ ÖZETİ

Kurumun Ajet Inflight projesi için 23.08.2024 tarihinde Fortify SCA aracı ile kaynak kodu analizi çalışmaları gerçekleştirilmiştir.

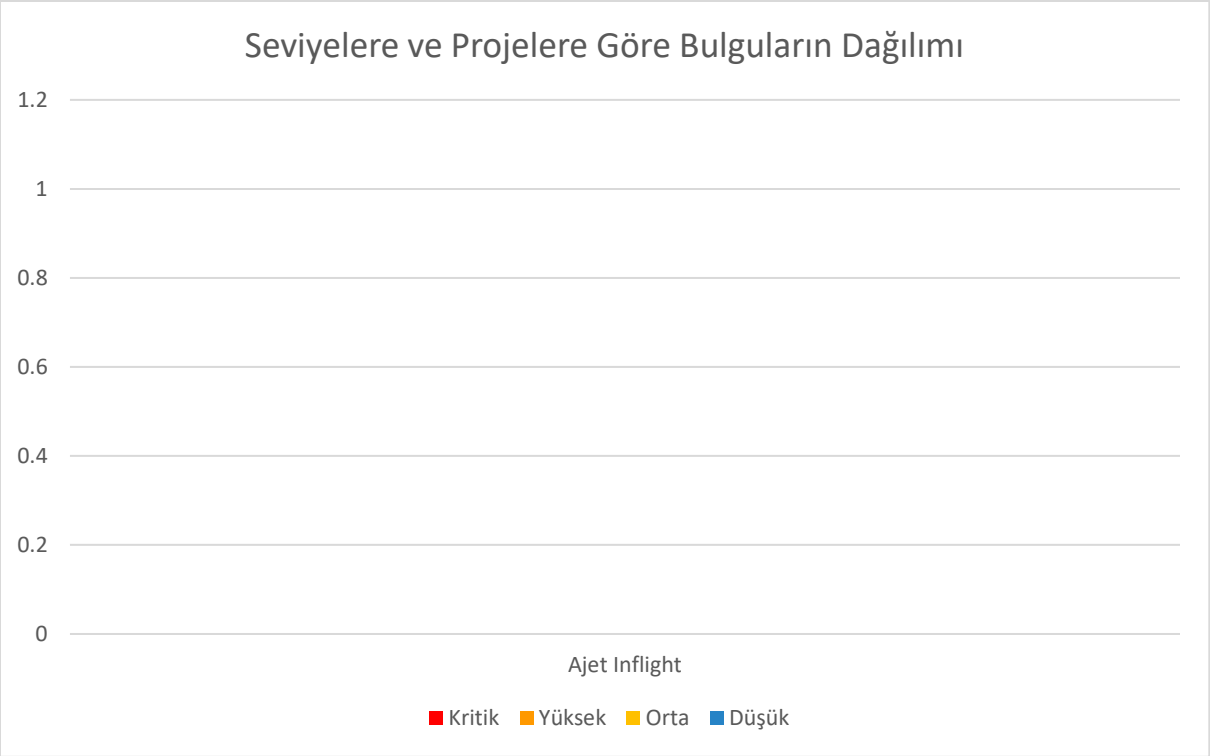
Analizler sonucunda herhangi bir bulgu tespit edilmemiştir.

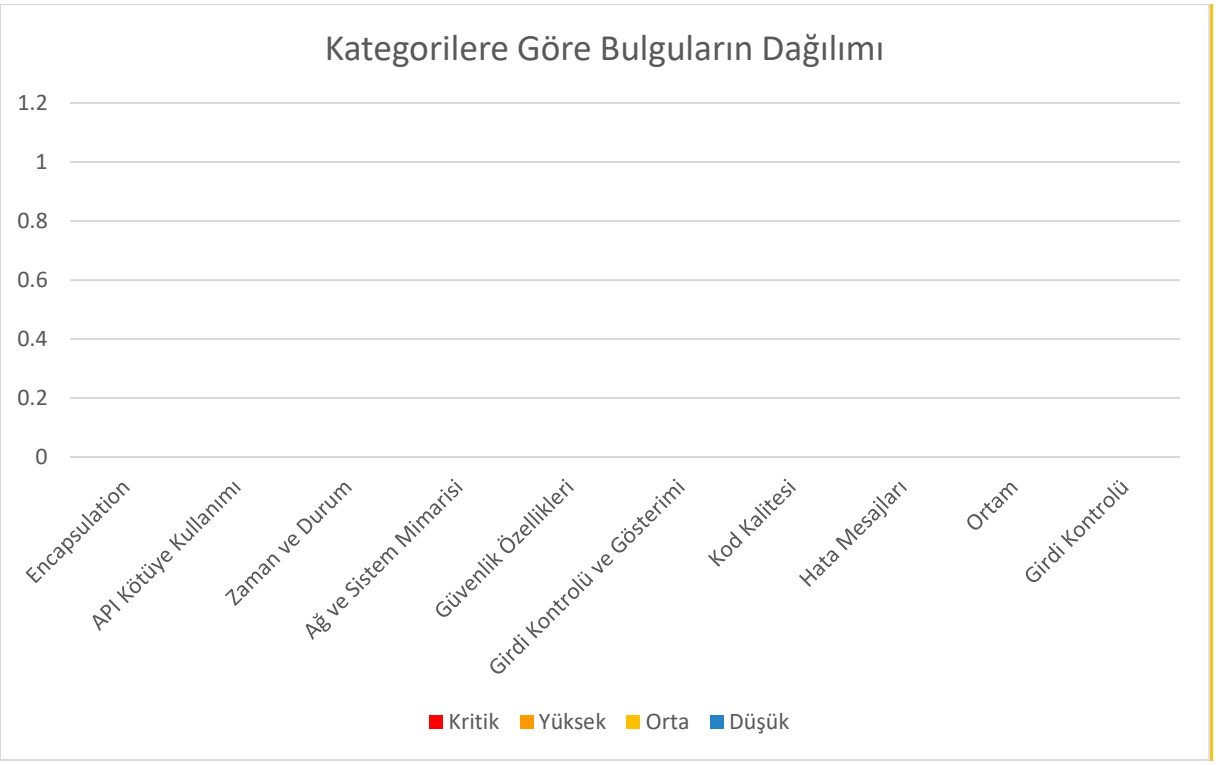
Bulgu Seviyeleri

Seviye	Açıklama
KRİTİK	Kritik öncelikli zafiyetlerin yüksek etkisi ve yüksek olasılığı vardır. Kritik öncelikli zafiyetlerin saptanması ve kullanılması kolaydır ve büyük varlık hasarına neden olur. Bu zafiyetler, uygulama için en yüksek güvenlik riskini temsil eder. Bu nedenle, derhal düzeltilmeleri gerekir.
YÜKSEK	Yüksek öncelikli zafiyetlerin yüksek etkisi ve düşük olasılığı vardır. Yüksek öncelikli zafiyetleri tespit etmek ve bunlardan yararlanmak genellikle zordur, ancak büyük varlık hasarına neden olabilir. Bu zafiyetler, uygulama için yüksek bir güvenlik riski oluşturur. Yüksek öncelikli zafiyetler, bir sonraki planlanan yama sürümünde giderilmelidir.
ORTA	Orta öncelikli zafiyetlerin etkisi düşük ve olasılığı yüksektir. Orta öncelikli zafiyetlerin saptanması ve kullanılması kolaydır, ancak genellikle küçük varlık hasarına neden olur. Bu zafiyetler, uygulama için orta düzeyde bir güvenlik riskini temsil eder. Orta öncelikli zafiyetler, bir sonraki programlanmış ürün güncellemesinde giderilmelidir.
DÜŞÜK	Düşük öncelikli zafiyetlerin etkisi ve olasılığı düşüktür. Düşük öncelikli zafiyetlerin tespit edilmesi ve kullanılması zor olabilir ve genellikle küçük varlık hasarına neden olur. Bu zafiyetler, uygulama için düşük bir güvenlik riskini temsil eder. Düşük öncelikli zafiyetler, zamanın elverdiği ölçüde giderilmelidir.

GİZLİ

Bulgu Grafikleri





Bulgu Kategorileri

Kök Neden	Açıklama
Girdi Kontrolü ve Gösterimi	Kullanıcı odaklı işlevsellik geliştirirken güvenilmeyen girdilerin hesaba katılmaması, en ciddi güvenlik açıklarından bazılarının sorumlusudur. Bu sorunlar şunları içerir: Buffer Overflow, XSS Saldırıları, SQL Injection ve diğerleri. Bu kategori, hatalı giriş filtreleme, alternatif kodlamalar ve sayısal gösterimlerden kaynaklanan sorunları kapsar.
Güvenlik Özellikleri	Bir yazılım sisteminin kritik işlemlerini korumaya yönelik güvenlik özelliklerinin mevcudiyeti, güvenli yazılımın geliştirilmesini hızlandırır. Ancak bu tür özelliklerin güvensiz kullanımı, amaçlarını tamamen ortadan kaldırabilir ve yazılım sistemini korumasız bırakabilir. Bu kategori, kimlik doğrulama, erişim denetimi, gizlilik, kriptografi ve ayrıcalık yönetiminin neden olduğu sorunları kapsar.
API Kötüye Kullanımı	Bir API, hem arayanların hem de arananların uyması gereken bir dizi kural oluşturur. Arayanın hangi eylemleri gerçekleştirmesi beklendiğini ve API'nin güvenli bir şekilde kullanılabilmesi için aranan kişinin hangi özelliklere sahip olması gerektiğini belirtir. Bu tür kurallara uymamak, API'nin kötüye kullanılmasına neden olur. İlgili kusurlara örnek olarak, hem arayanın anlaşmayı ihlal etmesi (örneğin, aranandan döndürülen değeri kontrol etmemesi) hem de arananın kuralları çiğnemesi (örneğin, bir equals() yönteminde bir boş parametre kontrolünün eksik olması) yer alır.
Zaman ve Durum	Yazılım sistemleri, özellikle bulut ve mobil bilgi işlemin gelişiyle daha karmaşık ve dağıtık hale geldikçe, belirli bir süre boyunca paylaşılan durum aracılığıyla gerçekleşen sistem bileşenleri arasındaki ve içindeki güvenli etkileşimler her zamankinden daha zorunlu hale geliyor. Tür koşulları, senkronizasyon sorunları ve kullanıcı oturumları arasında veri sızıntısı bu kategori tarafından temsil edilen kusurlara örnektir.
Hata Mesajları	Hata mesajları, saldırganlar tarafından yürütülen keşif faaliyetlerinin kolaylaştırılmasında önemli bir rol oynamaktadır. Yetersiz veya eksik hata işlemeden kaynaklanan uygulama yanlış davranışları, bu güvenlik açıkları kategorisine aittir.
Kod Kalitesi	Kalite ve güvenlik arasında ince bir çizgi vardır. Düşük kod kalitesi, her zaman güvenli olmayan kod anlamına gelmez, ancak çoğu zaman ciddi güvenlik açıklarına işaret edebilir. Kötü şöhretli "Apple goto fail" güvenlik açığı, güvenlik için ölü kod gibi kod kalitesi sorunlarının önemini vurgulayan mükemmel bir örnektir. Aynı şekilde, bellek sızıntıları da olası hizmet reddi sorunlarının göstergeleridir.
Encapsulation	İşlevsellik veya verilerin bulaşmayı önlemek için oluşturulan güven sınırlarını aşmasına izin veren hatalar bu kategori altında gruplandırılır. Veri erişim ayrıcalıklarının artması, güvenilmeyen kodun güvenli olmayan bir şekilde içe aktarılması ve korunmasız kaynaklar aracılığıyla bilgilerin açığa çıkması bu kategoriyi karakterize eden birkaç örnektir.
Ortam	Ortam kategorisi, güvenli olmayan dağıtım uygulamaları gibi kod uygulamasının dışında gerçekleştirilen eylemlerden kaynaklanan güvenlik sorunları sınıflarını gruplandırır. Güvenlik açıklarına neden olan yapılandırma hataları en iyi örnektir. Bu tür sorunlar kaynak kodun dışındadır ve bu nedenle diğer kategorilerin kapsamına girmez.

GİZLİ

Test Kapsamı

Testi Gerçekleştiren Firma RSU Bilişim ve Danışmanlık Hizmetleri A.Ş.		**Test Kapsamı Veri Sahibi Firma** Romsis Yazılım ve Bilgi Teknolojileri Ltd. Şti.
Testi Gerçekleştiren Personel Seçkin Güleviz		**Sorumlu Personel** Selim Tural
Raporu Hazırlan Seçkin Güleviz	**Raporu Kontrol Eden** Kaan İlter	**Raporu Yayınlayan** Kayhan Kayıhan
Test Başlangıç Tarihi 20.08.2024		**Raporlama Tarihi** 27.08.2024

Kapsam
• Romsis – Ajet Inflight Projesi
  ○ Commit: a55c0bde818008fef7ad617ae051cf5708f7b586
  ○ Branch: main
  ○ Tarih: 14.08.2024 09:21:07		

Uyarı

Rapor içeriği gizli olup iki tarafın yazılı mutabakatı olmadan üçüncü taraflara basılı olarak ya da elektronik ortamda transfer edilemez veya paylaşılamaz.

Rapor, tarama süresi içinde varlığı bilinen veya tarafımızdan tespit edilen güvenlik açıklıklarını içerecektir. Tarama işlemi bittikten sonra rapor teslim edilene kadar geçen süre içerisinde çıkabilecek yeni güvenlik açıklarına dair eksikliklerden dolayı RSU sorumlu tutulamaz.

Rapor içinde yer alan çözüm önerilerine konu hakkında fikir verme amaçlı yer verilmiştir. Çözüm önerilerinin uygulanması sebebi ile çıkabilecek problemlerden RSU sorumlu tutulamaz. Önerilerde sunulan değişikliklerden gerçekleştirilmeden önce konu hakkında uzman kişilerden destek alınması tavsiye edilir.

Kaynak Kodu Analizi Metodolojisi

1. Hazırlık ve Planlama
    - Çalışma tarihi ve ortamının planlanması
    - Proje özelinde teknolojilerin belirlenmesi
    - Test ortamının oluşturulması
2. Analiz
    - Proje özelinde analiz aşamaları:
        - Karakteristik Analizler
        - Konfigürasyon Analizleri
        - İçerik Analizleri
        - Kontrol Akışı Analizleri
        - Veri Akışı Analizleri
        - Yapısal Analizler
3. Bulguların Değerlendirilmesi
    - False-Positive bulguların ayıklanması
4. Raporlama
    - Raporun hazırlanması

Kaynak Kodu Analizi Bulguları

1. Kritik Seviye Bulgular

Kritik seviye bulgu tespit edilmemiştir.

2. Yüksek Seviye Bulgular

Yüksek seviye bulgu tespit edilmemiştir.

3. Orta Seviye Bulgular

Orta seviye bulgu tespit edilmemiştir.

4. Düşük Seviye Bulgular

Düşük seviye bulgu tespite dilmemiştir.